BRUTE FORCE ATTACK DETECTION & INVESTIGATION PLAYBOOK

Tier 1 SOC Analyst – Standard Alert Handling & Operational Response Procedure

Prepared By: Gunjan **Internship:** DG Interns Hub – Week 5 Task **Framework Mapping:** MITRE ATT&CK T1110

1. INTRODUCTION

1.1 What is a SOC Playbook?

A **SOC Playbook** (or Runbook) is a step-by-step procedure guide used by Security Operations Center analysts to investigate, triage, contain, and remediate specific types of security alerts. It acts as an operational standard to ensure all analysts follow consistent procedures during security events.

1.2 Purpose of This Playbook

This playbook provides Tier 1 (L1) SOC Analysts with a standardized procedure to investigate alerts associated with **Brute Force Attacks (MITRE ATT&CK T1110)**. It outlines step-by-step log analysis in Splunk, threat intelligence enrichment, severity classification, escalation guidelines, and containment actions.

1.3 Importance for an L1 SOC Analyst

Brute force attacks are among the most common initial access vectors targeting corporate networks. As an L1 analyst, rapidly distinguishing between a benign user password typo and an automated external brute force attempt is critical for protecting corporate credentials, meeting operational Service Level Agreements (SLAs), and preventing unauthorized network entry.

2. ALERT DESCRIPTION

2.1 What is a Brute Force Attack?

A **Brute Force Attack** occurs when an adversary systematically submits multiple username and password combinations using automated tools until correct credentials are found.

2.2 How Attackers Perform Brute Force Attacks

Direct Dictionary Attacks: Trying thousands of known passwords against a single specific account (e.g., `admin` or `root`). **Password Spraying:** Testing a small number of common passwords (e.g., `Summer2026!`) across hundreds of different user accounts to avoid triggering Active Directory account lockout thresholds. **Credential Stuffing:** Automated testing of stolen username/password pairs obtained from previous public data breaches.

2.3 System Impact & Windows Security Log Events

When an account experiences repeated failed authentication attempts, Windows Domain Controllers and endpoints record specific audit events in the Security Event Log:

Event ID 4625 (Failed Logon): Logged every time an authentication attempt fails due to an invalid password, bad username, or restricted logon hours. Key fields include `TargetUserName`, `WorkstationName`, `Source_Network_Address`, and `SubStatus` code. **Event ID 4624 (Successful Logon):** Logged when an authentication attempt succeeds. In a brute force scenario, observing Event 4624 immediately following a cluster of Event 4625s indicates potential account compromise. **Event ID 4740 (Account Locked Out):** Logged when an account exceeds the maximum allowed failed logon attempts set by domain policy.

3. ALERT SEVERITY & RISK DETERMINATION

An L1 SOC analyst must evaluate incoming brute force alerts to assign the correct severity rating:

Severity	Evaluation Criteria	Practical SOC Example
CRITICAL	High volume of failed logons followed by a **successful logon** on a Domain Controller or Domain Admin account.	150 failed attempts followed by Event 4624 for `domain_admin` from an external IP.
HIGH	Repeated failed logons targeting executive or administrative accounts from a known malicious external IP address.	300 failed SSH logins targeting `root` on a production server from an external IP with 95% AbuseIPDB score.
MEDIUM	Moderate volume of failed logons targeting standard user accounts from an unknown or public IP address.	25 failed RDP login attempts targeting a standard workstation account over a 10-minute window.
LOW	Low volume of failed logons from an internal workstation, likely caused by an expired saved password or typo.	6 failed attempts on an internal PC followed by a successful login by the assigned user.
INFO	Isolated single failed logon event generated during routine operations; no attack pattern present.	Single failed password entry on a workstation during regular business hours.

4. INITIAL TRIAGE STEPS

When a brute force alert appears in the SIEM dashboard, the L1 analyst must follow this 9-step triage protocol:

Acknowledge the Alert: Assign the ticket to yourself in the SIEM/SOAR portal to prevent duplicate triage. **Examine Core Metadata:** Record the exact rule title, detection timestamp (UTC), and initial severity rating. **Identify Target Account & Host:** Extract the affected username (`TargetUserName`) and hostname (`ComputerName`). Determine if the host is a critical asset (e.g., Domain Controller or Payment Gateway). **Identify Source IP Address:** Extract the origin IP (`Source_Network_Address`). Determine if the IP is internal (private ranges like `10.x.x.x`, `192.168.x.x`) or external. **Quantify Failure Volume:** Count total Event 4625 occurrences over the alert timeframe. **Check for Post-Failure Success:** Query SIEM for Event 4624 from the same source IP targeting the same account within 60 minutes after the failures. **Review Detailed Security Logs:** Inspect logon types (e.g., Logon Type 10 for RDP, Logon Type 3 for Network/SMB) and SubStatus error codes (e.g., `0xC000006A` = wrong password, `0xC0000064` = unknown user). **Identify Suspicious Patterns:** Check if multiple distinct user accounts were targeted sequentially from the same IP (Password Spraying). **Document Initial Findings:** Record all extracted indicators and context notes in the ticket log.

5. LOG ANALYSIS & SPLUNK INVESTIGATION

Splunk is used to aggregate and analyze raw Windows Security events. Below are standard Search Processing Language (SPL) queries used during brute force investigations.

5.1 Basic Detection Query (Failed Logins by Source IP)

```
index=win_logs EventCode=4625 | stats count by TargetUserName, Source_Network_Address,
ComputerName | where count > 5 | sort - count
```

SPL Breakdown:

`index=win_logs EventCode=4625`: Filters indexed Windows Security events specifically for failed logon events. `| stats count by TargetUserName, Source_Network_Address, ComputerName`: Groups and calculates the total failure count by username, source IP, and host. `| where count > 5`: Filters out minor typos, displaying only origins with more than 5 failed attempts. `| sort - count`: Sorts the results in descending order by highest failure volume.

5.2 Advanced Correlation Query (Successful Login After Repeated Failures)

```
index=win_logs (EventCode=4625 OR EventCode=4624) | stats count(eval(EventCode=4625))
as Failed_Count, count(eval(EventCode=4624)) as Success_Count by TargetUserName,
Source_Network_Address | where Failed_Count > 10 AND Success_Count > 0
```

SPL Breakdown: This query searches for instances where a single source IP generates more than 10 failed logon events (Event 4625) and subsequently achieves at least 1 successful logon (Event 4624) for the same user account. This pattern indicates a successful brute force breach.

> **Schema & Field Extraction Notice**
> Field names vary based on log parser configurations. For example, standard Splunk CIM maps source IP to `src_ip`, while native Windows Security logs render it as `Source_Network_Address` or `WorkstationName`. Analysts must verify field names in their environment.

6. THREAT INTELLIGENCE ENRICHMENT

When an external source IP is identified, the L1 analyst must query public Threat Intelligence platforms to gather reputation context:

VirusTotal: Submit the source IP into VirusTotal to inspect vendor detection scores, malicious domain resolution history, and associated malware hashes. **AbuseIPDB:** Query the IP address to review its *Abuse Confidence Score* (0–100%) and examine public reports submitted by other network admins regarding recent brute force or port scanning activity. **AlienVault OTX:** Search for the IP across public threat research dossiers (*Pulses*) to determine if it is linked to known adversary infrastructure or APT campaigns.

> **Important Caveat: Threat Intel is Supporting Evidence**
> Threat intelligence results provide context but must **NEVER** be treated as absolute proof. A brand new IP address used in an attack may show 0 reports on AbuseIPDB (false negative), while a legitimate cloud proxy IP may show previous reports due to shared hosting (false positive). Internal event logs take priority during triage.

7. DECISION CRITERIA: ESCALATE, CLOSE, OR MONITOR

After completing triage and enrichment, the L1 analyst must make a disposition decision:

Action	Triggering Conditions	Required Operational Step
ESCALATE TO L2	• Successful login (Event 4624) after repeated failures. • Brute force targeting Domain Admin / Executive accounts. • Password spraying targeting multiple distinct users. • Source IP flagged as high-risk malicious entity.	Create detailed escalation ticket, assign to L2 IR queue, and notify SOC lead immediately.
CLOSE TICKET	• Verified authorized internal security penetration test. • Confirmed user typo / misconfigured local script. • Low count from internal IP with verified user explanation. • No malicious indicators found.	Document exact communication proof, select "Closed - False Positive / Benign", and save ticket.
KEEP MONITORING	• Low-volume failed attempts from unknown IP without success. • Suspicious pattern lacking sufficient evidence for L2 escalation. • Account locked out (Event 4740) with attack stopped.	Add IP/User to 24-hour SIEM watch list, document baseline notes, and leave ticket open in watch status.

8. ESCALATION PATH & INFORMATION REQUIREMENTS

8.1 Role Responsibilities

L1 SOC Analyst: Perform initial triage, log extraction, threat intel lookups, ticket documentation, and initial decision. **L2 SOC Analyst:** Perform deep host forensics, host isolation via EDR, session termination, active breach containment, and root cause analysis. **SOC Team Lead:** Manage major incidents, coordinate executive communications, and oversee escalation SLAs.

8.2 Mandatory Information in Escalation Tickets

Escalation tickets must contain: **Alert ID & Timestamp (UTC)**, **Source & Destination IP Addresses**, **Targeted User Account & Hostname**, **Assigned Severity**, **Total Failed Login Count (Event 4625)**, **Successful Login Evidence (Event 4624 timestamps if present)**, **Threat Intel Scores**, **Chronological Investigation Steps Performed**, and **L1 Recommended Response**.

9. RECOMMENDED RESPONSE ACTIONS & AUTHORIZATION BOUNDARIES

Response actions must adhere strictly to SOC operational permission boundaries:

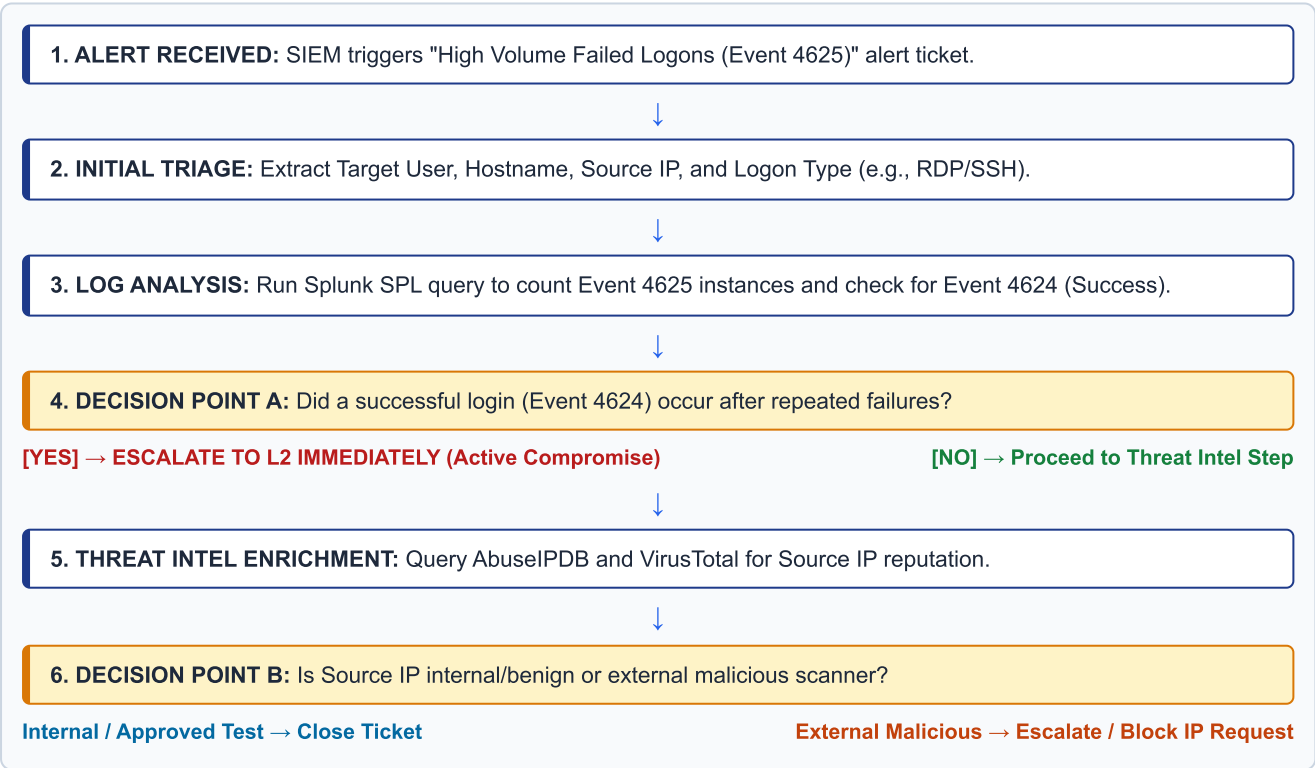
Response Action	Authorized Tier	Operational Context & Purpose
Initiate Account Lockout / Password Reset	L1 Analyst Authorized	Force password reset for targeted user account via Active Directory self-service or Helpdesk.
Document & Tag Ticket	L1 Analyst Authorized	Add internal SOC tags and attach threat intel screenshots to ticket history.
Perimeter IP Blocking at Firewall	L2 / Admin Approval Required	Submit edge firewall block request to restrict external malicious IP address.
EDR Host Network Isolation	L2 / Admin Approval Required	Disconnect compromised endpoint from the network via EDR agent to prevent lateral movement.
Domain Account Disablement	L2 / Admin Approval Required	Disable executive or critical domain account in Active Directory during active breach.

10. DOCUMENTATION REQUIREMENTS

Every ticket triaged by an L1 analyst must contain an auditable record including:

Alert Summary: Rule Name, Alert ID, Timestamp, Severity. **Timeline of Events:** Exact start time of brute force, peak activity window, and time of triage. **Log Evidence Snippets:** Raw Splunk search results, Event 4625 counts, and Event 4624 verification. **Enrichment Results:** VirusTotal score, AbuseIPDB report count, and IP geolocation. **Disposition Justification:** Detailed narrative explaining why the ticket was closed, monitored, or escalated.

11. INVESTIGATION FLOWCHART



12. PRACTICAL HYPOTHETICAL TRAINING SCENARIO

[HYPOTHETICAL TRAINING SCENARIO - FOR CASE STUDY PURPOSES ONLY]

Alert Title: Potential RDP Brute Force Attack Followed by Successful Authentication

Alert ID: SIM-2026-99104 | **Severity:** CRITICAL | **Time:** 2026-10-31 09:12:00 UTC

Parameters: Source IP: `198.51.100.44` (External) | Destination: `10.0.1.50` (`SRV-FINANCE-01`) | Account: `corp\finance_admin`

Splunk Findings: SPL query revealed 142 Event 4625 occurrences between 09:05 and 09:11 UTC. At 09:11:45 UTC, 1 Event 4624 (Logon Type 10 - RDP) was recorded from the exact same source IP.

Threat Intel Lookup (Illustrative): AbuseIPDB Score: 96% Malicious (180 reports for RDP brute force). VirusTotal: IP associated with malicious scanner feeds.

L1 Analyst Decision: ESCALATE TO TIER 2 IMMEDIATELY. High-confidence True Positive indicating successful administrative account breach. Ticket escalated with recommendation to isolate host `SRV-FINANCE-01` and reset user credentials.

13. QUICK REFERENCE CHECKLIST FOR L1 SOC ANALYSTS

Use this single-page operational checklist during live alert triage:

Step	Action Item	Operational Verification / Task Details	Status
1	**Acknowledge Ticket**	Assign ticket to self in SIEM/SOAR portal to establish SLA tracking.	[ ] Done
2	**Extract Metadata**	Record Alert ID, exact UTC detection timestamp, and initial severity level.	[ ] Done
3	**Identify Source & Target**	Identify Source IP, Destination Host, and targeted Username(s).	[ ] Done
4	**Check Event 4625 Count**	Run Splunk SPL to determine total failure count and attack timeframe.	[ ] Done
5	**Check Event 4624 (Success)**	Verify if a successful logon occurred after failure cluster (Critical indicator).	[ ] Done
6	**Check Account Importance**	Determine if target account is standard user, executive, or Domain Admin.	[ ] Done
7	**Query Threat Intel**	Search Source IP on AbuseIPDB, VirusTotal, and AlienVault OTX.	[ ] Done
8	**Determine Classification**	Classify event as True Positive, False Positive, or True Negative.	[ ] Done
9	**Apply Response Action**	Initiate authorized L1 password reset or compile L2 escalation ticket.	[ ] Done
10	**Final Documentation**	Attach Splunk logs, threat intel notes, and formal disposition to ticket.	[ ] Done

14. LEARNING REFERENCES & OFFICIAL DOCUMENTATION

- MITRE ATT&CK Framework - Technique T1110 (Brute Force): **https://attack.mitre.org/techniques/T1110/**
- Microsoft Security Audit Log Reference (Event 4625, 4624, 4740): **https://learn.microsoft.com/**
- Splunk Enterprise Search Reference Guide (SPL Syntax): **https://docs.splunk.com/**
- AbuseIPDB IP Reputation API Documentation: **https://www.abuseipdb.com/**
- VirusTotal Threat Intelligence Knowledge Base: **https://www.virustotal.com/**

> **Document Completion Verification**
>
> This document concludes the formal **SOC Playbook – Brute Force Attack Detection & Investigation** submission for Week 5 of the DG Interns Hub Cybersecurity Internship Program (Prepared by: Gunjan).